A128CBC-HS256	256 (128+128)	128	280 trillion	128
A192CBC-HS384	384 (192+192)	128	280 trillion	192
A256CBC-HS512	512 (256+256)	128	280 trillion	256

GCM was designed for use in protocols like TLS where a unique session key is negotiated for each session and a simple counter can be used for the nonce. If you reuse a nonce with GCM then almost all security is lost: an attacker can recover the MAC key and use it to forge tokens, which is catastrophic for authentication tokens. For this reason, I prefer to use CBC with HMAC for directly encrypted JWTs, but for other JWE algorithms GCM is an excellent choice and very fast.

CBC is a widely used mode that is less efficient than CTR mode, but still secure when used correctly. CBC requires the input to be padded to a multiple of the AES block size (16 bytes), and this historically has led to a devastating vulnerability known as a *padding oracle attack*, which allows an attacker to recover the full plaintext just by observing the different error messages when an API tries to decrypt a token they have tampered with. The use of HMAC in JOSE prevents this kind of tampering and largely eliminates the possibility of padding oracle attacks, and the padding has some security benefits.

> **WARNING** You should avoid revealing the reason why decryption failed to the callers of your API to prevent oracle attacks like the CBC ***padding oracle attack***.

What key size should you use?